

Lernfeld 4 · IT-Sicherheit

Kompakte Prüfungs-Zusammenfassung: Bedrohungen, IT-Grundschutz, Schutzziele, ISMS, DSGVO und technische Maßnahmen.

1 · IT-Grundschutz: Modellierung

Zielobjekte (Prozesse, Anwendungen, IT-Systeme, Netze, Räume, Gebäude) werden mit passenden **Bausteinen** des IT-Grundschutz-Kompendiums abgebildet. Das Modell zeigt, welche Anforderungen gelten und wo Lücken bestehen.

Vererbung des Schutzbedarfs

- **Maximalprinzip:** Objekt übernimmt den höchsten Schutzbedarf von allem, was es trägt.
- **Abhängigkeit:** Hängt ein Objekt von einem anderen ab, wird dieses mitbetrachtet.
- **Kumulation:** Viele kleine Objekte ergeben zusammen höheren Bedarf (z. B. VM-Host).
- **Verteilung:** Bedarf kann sinken, wenn eine kritische Aufgabe verteilt ist (begründet reduzieren).

Anforderungsstufen & Verbindlichkeit

Basis	vorrangig umzusetzen
Standard	Stand der Technik
Erhöht	zusätzlich bei hohem Schutzbedarf
MUSS / DARF NUR	verbindlich
DARF NICHT	ausgeschlossen
SOLLTE	grundsätzlich – Abweichung begründen

Anforderungen sagen **was** zu erreichen ist, nicht **wie**. Maßnahmen müssen wirksam, geeignet, praktikabel, akzeptiert und wirtschaftlich sein.

Schichten/Bausteingruppen

Prozess (1×/Verbund)	ISMS, ORP, CON, OPS, DER
System (je Objekt)	APP, SYS, IND, NET, INF

2 · Bedrohungen & Angriffsmethoden

Nicht jede Bedrohung ist Schadcode – auch fehlende Prozesse, schwache Organisation und physische Risiken zählen.

Angriffskette (vereinfacht)

Initialzugang → Ausführung → Persistenz → Rechteausweitung → seitliche Bewegung → Exfiltration/Wirkung

Wichtige Kategorien

Malware	Viren, Würmer, Trojaner, Ransomware (Verschlüsselung + Erpressung), Spyware.
Social Engineering	Phishing, Spear-Phishing, Pretexting, Baiting – Mensch als Schwachstelle.
Web-Angriffe	SQL-Injection, XSS, CSRF – Eingaben nie ungeprüft vertrauen.
Netz/Cyberphysisch	MITM, DoS/DDoS, Spoofing, Angriffe auf OT/ICS.
KI-Bedrohungen	Prompt Injection, Deepfakes, automatisiertes Phishing.

3 · Schutzziele & Grundbegriffe

Vertraulichkeit	Nur Befugte haben Zugriff (Confidentiality).
Integrität	Daten sind unverändert/korrekt (Integrity).
Verfügbarkeit	Systeme sind nutzbar, wenn benötigt (Availability).

Authentizität	Echtheit der Identität/Herkunft.
Verbindlichkeit	Handlungen sind nachweisbar (Nichtabstreitbarkeit).

4 · ISMS & Management

Ein **ISMS** (Information Security Management System) steuert Informationssicherheit systematisch – nach dem **PDCA-Zyklus**: Plan → Do → Check → Act.

- Leitung trägt Verantwortung (Top-Management-Commitment).
- Sicherheitsleitlinie, Rollen, Risikomanagement, kontinuierliche Verbesserung.
- Normen: BSI IT-Grundschutz, ISO/IEC 27001.

5 · DSGVO & Datenschutz

Personenbezug	Daten über identifizierbare natürliche Personen.
Grundsätze	Zweckbindung, Datenminimierung, Speicherbegrenzung, Rechtmäßigkeit.
Betroffenenrechte	Auskunft, Berichtigung, Löschung, Datenübertragbarkeit.
Meldepflicht	Datenpanne i. d. R. binnen 72 h an die Aufsichtsbehörde.
TOM	Technische & organisatorische Maßnahmen zum Schutz.

6 · Technische Schutzmaßnahmen

Firewall	Filtert Netzverkehr nach Regeln (Paketfilter, Stateful, Proxy).
Verschlüsselung	Symmetrisch (1 Schlüssel) vs. asymmetrisch (Public/Private Key); TLS, VPN.
Datensicherung	3-2-1-Regel: 3 Kopien, 2 Medien, 1 extern/offline.
Authentifizierung	Starke Passwörter, MFA/2FA, Rechtekonzept (least privilege).
Lizenzen	Proprietär, OSS, Freeware, Shareware – Nutzungsrechte beachten.

3-2-1-Backup schützt gegen Ransomware, Brand und Diebstahl – mindestens eine Kopie offline/offsite.